

STATEMENT OF WORK (SOW)

Office of Investigations Case Management (OICM) Services

Department of Veterans Affairs Office of Inspector General (VA OIG) Office of Investigations

Dated: March 20, 2026

Title and Scope

The Department of Veterans Affairs (VA) Office of the Inspector General (OIG) Office of Investigations (OI) requires a commercial off-the-shelf (COTS) solution to provide OICMS Services and services related to its installation. The new COTS system will be OI system of record and will technically modernize and replace parts of the VA OIG Enterprise Management System (EMS) and transition OI from paper case files to electronic case files.

The COTS solution shall allow OI employees to create, maintain, retrieve, and manage all data related to investigations; generate investigative and statistical reports based on that data; the Contractor shall provide services that allow for configuration and customization to OI's business processes, and user roles.

Background

The mission of the VA OIG Office of Investigations (OI) is to investigate potential crimes and civil violations of law involving VA programs and operations committed by VA employees, Contractors, beneficiaries, and other individuals. These investigations focus on a wide range of matters including healthcare, procurement, benefits, construction, and other fraud; cybercrime and identity theft; bribery and embezzlement; drug offenses; and violent crimes.

OI is staffed by special agents with full law enforcement authority, forensic auditors, and other professionals. OI staff use data analytics, cyber-tools, covert operations, and other strategies to detect and address conduct that poses a threat to or has harmed veterans or other beneficiaries and VA personnel, programs, operations, and property. Through criminal prosecutions and civil monetary recoveries, OI's investigations promote integrity, patient safety, efficiency, and accountability within VA. OI is also responsible for conducting personnel security and suitability background investigations.

The OIG has an existing case management system called the Enterprise Management System (EMS), which is a .NET application using Structured Query Language (SQL). EMS consists of customized applications to maintain information pertaining to investigations, hotline allegations, and congressional and public affairs inquiries. However, EMS is not adequate for the future. For example, the user interface and system integration are not optimized for streamlined investigative case management.

Objectives

1. **The Contractor shall provide a commercial off-the-shelf (COTS) investigative case management system to technically modernize OI's current investigative case management system.** The Contractor shall:
 - a. Deliver software licensing containing the features needed to meet the requirements outlined in the Performance Work Statement (SOW).
 - b. Deliver a COTS investigative case management system no later than (NLT) 12 months from the date of contract award that includes all identified existing case data successfully migrated from the existing case management system.
2. **The Contractor shall provide services for the COTS investigative case management system to meet OI requirements.** The Contractor shall:
 - a. Provide documentation, installation, configuration, deployment, maintenance support, and training to successfully implement a new case management system.
 - b. Deliver services to successfully migrate data from OI's existing case management system into the COTS solution in accordance with the Technical Requirements outlined in the SOW.
 - c. Provide technical and customer support to OI as required in the SOW.

Technical Requirements

1. COTS Investigative Case Management System

- a. The Contractor shall provide a commercial off-the-shelf (COTS) investigative case management system to replace and technically modernize OI's current investigative case management system. This includes providing software licensing necessary for OI to fully utilize the new case management system.
 - i. This system shall have a highly configurable interface that allows users to customize design elements (e.g., labels, drop menus, dashboards, etc.).
 - ii. This system shall have the ability for system administrators to set the global policy for user interface configuration and allow individual users to configure their own personal settings.
 - iii. The case management system shall be a single inclusive, scalable case management system to record, track, and display accurate and current information on OI investigations (e.g., the system should display up-to-date information on investigative activities, evidence, judicial results, and case information for the OI).
 - iv. The case management system shall provide capabilities for document management, workflow and reporting, contact/referral intake, evidence management, and case tracking to include a capability to track and document personnel time spent on these activities.
- b. The Contractor shall deliver a case management system that contains the following core capabilities (at a minimum):
 - i. Logical access controls and management with advanced role-based internal controls to protect sensitive data including, but not limited to, internal affairs investigations, undercover and confidential sources, grand jury material, etc.

- ii. Investigation case management that is customizable and configurable, including the ability to open investigations, make referrals, conduct case reviews, close, and track results with current or future machine learning features.
- iii. Configurable bi-directional workflows and approval levels (one-to-one and one-to-many).
- iv. Visible audit trails to record system activity at the individual user level with date and time stamps. Activities include, but are not limited to searches, case access, and changes made to contacts, cases, and system.
- v. Capability to generate templated and/or customizable letters/emails containing auto-filled information from any data field in the system; capability to sign and print the letters, save as PDF, and directly send with email.
- vi. Employee roles/actions, associated with contacts and cases, will be retained as part of the record regardless of an employee's change in status (transferred, retired, etc.).
- vii. Customizable, ad-hoc, and pre-built reports that include but are not limited to investigative statistics and data points specific to OIG's oversight work. Recurring reports, for instance, are required by the Inspector General Act, the Attorney General Guidelines, and the Council of the Inspectors General on Integrity and Efficiency (CIGIE). Customizable reports, for instance, include number of cases opened, number of hours spent on investigations, counts of types of cases, counts of prosecutions, counts of operations, slicing of this data per organizational unit or division).
- viii. Ability to create sub-modules or sub-case environments for specialized elements or support groups to receive, display, and distribute information, track incoming requests, and organize the compartmentalized information. These sub-modules shall have the ability to connect cases or information to the main case management system.
- ix. Advanced search of new and legacy files (including text, documents, files, and data fields) with drill-down capability, Soundex-like capability, and typo tolerance.
- x. Internal (within OIG) support services request feature with the ability to generate and request support tickets including, but not limited to, analytical, technical operations, subpoenas, and desk office support.
- xi. Report automation allowing for auto-filled information from any data field in the system (case activity notes, synopsis, etc.), attachment of documents, and other exhibits related to the case. Also allow for attachments or other records in the case to be linked to a generated report for simple reference and review.
- xii. Investigation activity and technique management to include IG subpoena generator, overt and covert law enforcement operations planning, consensual/electronic monitoring requests and result reporting, and other law enforcement specific investigative activities and techniques.
- xiii. Undercover and confidential source documentation capability, to include contact information separate from general system contacts/entities.
- xiv. IG subpoena generator and management that builds, prints to PDF, links to specific case file, and tracks IG subpoenas. This includes a database of frequent or previously entities who were issued IG subpoenas with the ability to update address/contact information.

- xv. The system should be URL addressable and allow for keys to be passed into the web application such that a specific record, profile, or case can be rendered. The URL strings shall not include PII. URL addressing shall not allow for bypass or override of access controls including but not limited to search.
- xvi. Tracking time associated with investigations and investigative activity, law enforcement availability pay (LEAP) hours, training hours, physical fitness hours, and other direct and indirect time.
- xvii. Record input, retention, queries and report generation for employee certifications, training records, assigned law enforcement equipment, etc.
- xviii. Tracking and reporting for government vehicles, including vehicle inventory, including those assigned by region and agent; vehicle mileage (with capability to specify usage amount and purpose, including home-to-work); vehicle maintenance, accident, and safety information.
- xix. Evidence management within the investigative case file with barcoding and multi-site capabilities. Web or app-based access for evidence collection and logging using barcodes generated by the system, to identify individual items of evidence. Ability to use VA OIG issued smartphones to scan barcodes for inventory purposes. Barcodes will be formatted to use existing government hardware with the ability to print on commercially available labels.
- xx. Data migration, integration, and interoperability with existing OIG, VA, and external applications via application programming interface (API) and other means.
- xxi. Print, export, and download capability for all cases for legal discovery and archiving. This capability should include selecting documents or the entire file in a consumable format.
- xxii. Ability to upload document and media files that exists in electronic digital images, audio, and video formats. Within attachments, the ability to tag images, audio files, and video files with associated cases and keywords, and the creation of hash values associated with all electronic files. The system shall support file uploads up to 10GB per file to ensure adequate data transmission and storage capacity.
- xxiii. Ability to scan and load documents into the system with optical character recognition (OCR).
- xxiv. Mobile-friendly interfaces via mobile application that allows users to access work, search within the case management system, and upload files to specific cases or folders.
- xxv. Automatic name check deconfliction to ensure no duplication of entities both upon search and entry.
- xxvi. Provide an optimized database that fully supports advanced visualization of dashboards, reporting, and data analysis.
 - 1. Provide users with link analysis functionality that can be automatically and manually created.
 - 2. Includes geospatial analysis and map tools that can be searched, filtered, and marked up.

3. Provide the ability to send/transmit email, mobile application, or web application alerts. Alert settings should be customizable by the individual user and include but not limited to case statuses, due dates, new assignments, document corrections, and approval notices.
 4. Provides the ability to create timelines from various data points or information sets within the case management system.
 5. Customizable dashboards that provide the ability for all users to display information captured and related to their investigations.
- xxvii. Ability to track eDiscovery, digital forensics, and technical operation media volume and statistics in support of investigations (e.g., a primary case owner's request for assistance requires response from support personnel; the system should be able to track this support activity, which could include, for instance, forensic analysis of 1000 bank records, forensic examination of data, or forensic computer analysis).
 - xxviii. Ability to enter and maintain investigative notes.
 - xxix. Ability to integrate internal VA and VA OIG records and data, including, but not limited to, employee master file, to automatically populate specified fields.
 - xxx. Ability to provide licenses to users outside of the organization for case information, documents, or data reviewing within the case management system.
 - xxxi. Ability to scale to and/or incorporate artificial intelligence (AI) capabilities throughout the case management system.
- c. The new COTS investigative case management system shall offer comprehensive API endpoints that deliver data in standard formats like JavaScript Object Notation (JSON) to facilitate direct backend database access to optimize performance and flexibility.
 - d. The Contractor shall provide data storage capabilities with at least 10 TB of storage capacity. This includes, but is not limited to, the ability to scale dynamically to accommodate increases in data volume, ensuring continuous availability and optimal performance without interruptions due to storage constraints.
 - e. The Contractor shall provide a system that allows web form integration/functionality, dashboard and notifications, task assignment, contact data recording, workflow and routing, referrals and tracking, and reporting, to include, but not limited to, the detailed list of requirements shown SOW section 1.b.
 - i. For example, the system should have the ability to automatically generate documents using defined templates and populate with selected information from the database; generate alerts related to events or any user definition and accommodate many searchable data fields.

2. COTS Investigative Case Management Services

- a. The Contractor shall provide services for the successful implementation, configuration, and data migration of the new COTS investigative case management system to meet OI requirements.
 - i. Implementation and Configuration
 1. The Contractor shall configure the system for maximum interoperability across VA OIG offices to ensure flexibility in exchanging information/integration with OIG's existing applications and reporting tools (e.g., eCase, Genesys, Teammate, FOIA Xpress, and the Microsoft 365

suite, etc.) and third-party tools including at a minimum Microsoft Power BI and Dynamics, and Tableau. This interoperability shall incorporate the use of an open systems standards-based solution which addresses net-centric objectives (including continuity of operations, back-up, and recovery).

2. The Contractor shall provide a configuration plan that outlines the steps that will be taken to configure the software to OIG's specifications including (but not limited to):
 - a. setting up rules and policies
 - b. customizing access and user or group security roles and associated rights
 - c. developing and implementing any specific global/universal terminology
 - d. developing and implementing project templates
 - e. setting up groups for access to project data and information
 - f. generating customized dashboard views for project and overall OIG
 - g. performance tracking and configuring all custom fields available within the software
 - h. The Contractor shall provide a configuration control document capturing all baseline system configurations as well as configuration change logs
 - i. The Contractor shall provide a Configuration Management tool to track changes and software release deployment.
3. The Contractor shall provide staging environments for the COTS case management system, to include but is not limited to Development, Pre-Production, and Quality Assurance. The Contractor shall provide VA OIG access to these environments as part of this effort. Validation and verification actions will occur in one or a combination of these environments before VA OIG approves the solution to be deployed to the Production environment. VA OIG's validation and verification does not relieve the Contractor of its responsibility to comply with all requirements under the Contract.
4. The Contractor shall provide an implementation plan that outlines the business cases, steps, and timeframes that will be followed for all phases of software implementation and data migration. The implementation plan will include (but is not limited to) implementation of working discussions, installing software and maintenance updates, user access, system security, and delivery of software.
5. The Contractor shall provide integrated control documentation that includes, but is not limited to, up-to-date details on data mapping and procedures for real- or near-real-time data exchange between the product and the existing OIG case management system. The integrated control documentation shall also include, but is not limited to:

- a. The Contractor shall provide an automated notification process regarding changes to any data elements.
- b. The Contractor shall establish a baseline integrated control document (ICD) to include all required data elements to other OIG systems.

ii. System Access

1. The Contractor shall configure and implement user rights, permissions, and access to system records. These activities include ensuring the case management system has the following capabilities:
 - a. Capability to manage access controls, including read-only viewing, for each directorate by either group or individual. For example, the OI directorate must have the ability to grant an OIG employee outside of the OI read-only access to a case file after executive leader approval.
 - b. Ability for investigative staff to have remote or mobile utilization to the solution via a Government furnished smart phone or other device.
2. The Contractor shall provide uninterrupted and unrestricted access to the data 24 hours a day, seven (7) days a week. The access shall be free from artificial constraints such as rate limits, throttling, or other access restrictions that could impede data use.

iii. Data Migration

1. The Contractor shall deliver services to successfully migrate data from OI's existing case management system into the COTS solution. This includes all existing data in OI's current investigative case management system that shall be successfully imported, validated, and certified into the new system format.
2. The Contractor shall successfully migrate identified existing case data from the existing casement system into the COTS solution before the COTS solution is live in the Production environment.
3. The Contractor shall provide OIG with a data migration plan with strategy for conducting and analyzing the existing data, workflows, permissions, and other aspects within the legacy EMS system. The plan and analysis provided to OIG shall include, but is not limited to ICD, data dictionary for the COTS case management system, schema, source-to-target mapping, and similar artifacts that show the planned migration between systems along with identifying any data fields, storage objects, etc. that may be at risk. The migration plan shall include a crosswalk from OI's current investigative case management system to the new case management system to ensure data is migrated to the appropriate location within the new system. The migrated data shall adhere to the advanced search requirements documented in the Technical Requirements section (above).

4. The Contractor shall provide up-to-date detailed information describing the contents, format, and structure of the case management database and the relationship between its elements of the product throughout the life cycle of the product. This information shall be documented in a Data Dictionary.
- b. The Contractor shall assist the OI in implementing business rules, data mapping, and processes to support information workflows and business process efficiencies based upon the new COTS investigative case management system. This ties to training OI in new business processes based on how the system works.

Non-Technical Requirements

1. 508 Compliance

- a. The Industry Partner shall support the Government in its compliance with Section 508 throughout the development and implementation of the work to be performed. Section 508 of the Rehabilitation Act of 1973, as amended (29 U.S.C. § 794d) requires that when Federal agencies develop, procure, maintain, or use electronic information technology, Federal employees with disabilities have access to and use of information and data that is comparable to the access and use by Federal employees who do not have disabilities, unless an undue burden would be imposed on the agency. Section 508 also requires that individuals with disabilities, who are members of the public seeking information or services from a Federal agency, have access to and use of information and data that is comparable to that provided to the public who are not individuals with disabilities, unless an undue burden would be imposed on the agency. Applicable standards are 36 C.F.R §§1194.21-1194-26.
- b. The Contractor should review the following websites for additional 508 information:
 - i. <http://www.section508.gov/index.cfm?FuseAction=Content&ID=12>
 - ii. <http://www.access-board.gov/508.htm> <http://www.w3.org/WAI/Resources>
- c. The Contractor must indicate in its proposal where full details of compliance to the identified standards can be found, such as Contractor's website, etc.

2. Security Compliance

- a. The Contractor shall provide a system that is compliant with all applicable Federal security, privacy, technical, and functional directives.
- b. The Contractor shall provide a solution that is capable of being deployed in **at least one (1)** of the following methods in accordance with the requirements of OMB Memorandum 24-15:
 - i. **FedRAMP Authorized Solution** - The Contractor's solution is fully FedRAMP authorized as evidenced by an active FedRAMP Authority to Operate (ATO). The Contractor's solution must be able to be implemented at a FedRAMP Impact Level of Moderate or higher with the capability of adding security control overlays as defined by NIST, if needed, and maintain compliance with FedRAMP requirements throughout the period of performance, or;

- ii. **Deployment on Single Agency Private Cloud** - The Contractor is fully capable of deploying the solution on a customer-provided, single-agency private cloud. The solution must comply with all applicable security and performance standards, including those outlined in the agency's security policies, FISMA Law, NIST guidance and standards, and OMB mandates.
- c. The solution shall support data-at-rest (DAR) and data-in-transit (DIT) encryption using FIPS 140-2 or 140-3 certified cryptomodules as certified by <https://csrc.nist.gov/projects/cryptographic-module-validation-program/validated-modules>. This encryption requirement also applies to mobile applications. Additionally, some mobile applications require registration through the VA Mobile Device Management (MDM), which any application must satisfy, as required by Executive Order (EO) 14028.
- d. The solution shall adhere to Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors (HSPD-12) compliance.
- e. The Contractor shall ensure that the solution provides the capability for OI to specify particular records retention periods in a no-code environment. This functionality shall exist in a case, issue, or document basis, which may be time-based or permanent. Records retention capability is needed for statutory and regulatory records requirements (e.g., from the National Archives and Records Administration, Department of Homeland Security, and Cybersecurity and Infrastructure Security Agency), along with litigation holds and Freedom of Information Act requests.
- f. Logging shall meet or exceed OMB M-21-31 Event Logging 3 requirements including "cloud storage" requirements. OIG may determine whether to allow lower compliance, but the solution must meet at least Event Logging 2 requirements. OIG may specify other logging requirements including but not limited to Certified Information Systems Auditor (CISA) Emergency Directive or OIG incident response requirements. Contractor must presume that all logging requirements for the solution must be fulfilled by the cloud solution.

3. General Requirements

- a. The Contractor shall provide a solution that supports modern browser standards for Microsoft Edge, Google Chrome, and Safari.
- b. If using a web browser, the solution shall use Hypertext Transfer Protocol Secure (HTTPS) on port 443 for all information transmission. The solution shall comply with Federal TLS requirements and any other technical requirements specified by OIG.
- c. The solution shall be certified as compatible with the latest applicable Microsoft Operating System (OS).
- d. The Contractor shall support the solution being added to the VA OIG inventory system.
- e. The solution shall be capable of single sign-on (SSO) using VA-issued PIV cards and credentials generated by the VA Entra ID (Active Directory) identity and access management tenant as required by HSPD-12 (Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors).
- f. The Contractor shall ensure the solution meets the following metrics:
 - i. Supports initial userbase of 325 concurrent users across Investigations and other OIG offices with the ability to be scalable to meet an increased user base.

- ii. Database must be compatible with Microsoft Windows Server 2019 or higher and Microsoft SQL Server 2019 or higher.
- iii. COTS product (when operational) is available to users with 99.9% uptime.
- iv. Once an employee (account) is associated with an action in a contact/case, that user association must remain indefinitely even if the employee departs OIG, and the associated Active Directory account is deleted/disabled.
- v. The solution shall have the capability to run reports on user account activity including, but not limited to, logon to the solution and access to individual case files.

4. Testing

- a. The Contractor shall provide a detailed test management plan (TMP) that describes the objectives, resources, and processes for successfully testing the COTS solution. The TMP shall also include (but is not limited to) entrance and exit criteria, a Requirements Traceability Matrix, Test Case/Procedure, Test Scripts, Test Schedule, and Test Reports.

Other Requirements

1. Onboarding Support

- a. Onboarding support shall have a period of performance (PoP) of three (3) months from the date of contract award. At the conclusion of the PoP, all Contractor staff shall be successfully onboarded to support this effort. The Contractor shall manage the onboarding process for VA OIG access and individual system/environment access for all Contractor staff support this effort. The Contractor shall collect signed rules of behavior documents, signed non-disclosure documents, training certificates, and other onboarding related information. The Contractor shall provide the files and information outlined in the Security Annex for this effort. The Contractor shall monitor the submission of the artifacts and follow up with Contractors to ensure that all artifacts submitted are complete and correct. The Contractor shall also track VA OIG system access requests, for assigned projects, to completion. The Contractor shall document all findings in the Daily Onboarding Status Report.

2. Contract Kickoff

- a. A contract kickoff meeting shall be held within 5 business days after award. The Contractor shall coordinate the date, time, and location (can be virtual) with the Contracting Officer (CO), the VA OIG PM, and the COR. The Contractor shall provide a draft agenda to the CO and VA PM at least two (2) business days prior to the meeting. Upon Government approval of the final agenda, the Contractor shall distribute to all meeting attendees.
- b. During the contract kickoff meeting, the Contractor shall present an overview of the intended approach, work plan, project team, and applicable contact information for each effort via a Microsoft Office PowerPoint presentation.

3. Technical Kickoff

- a. A technical kickoff meeting shall be held within 5 business days after award. The Contractor shall coordinate the date, time, and location (can be virtual) with the CO, the VA OIG PM, and the COR. The Contractor shall provide a draft agenda to the CO and VA PM at least three (3) business days prior to the meeting. Upon Government approval of the final agenda, the Contractor shall distribute to all meeting attendees.
- b. During the technical kickoff-meeting, the Contractor shall present, for review and approval by the Government, the details of the intended approach, work plan, and project schedule for each effort via a Microsoft Office PowerPoint presentation. At the conclusion of the meeting, the Contractor shall update the presentation with a final slide entitled "Summary Report" which shall include notes on any major issues, agreements, or disagreements discussed during the kickoff meeting. The Contractor shall submit the final updated presentation to the COR for review and approval within three (3) business days after the meeting. The Contractor shall obtain concurrence from the COR on the content of the meeting minutes prior to distribution of the document.

4. Project/Schedule Management

- a. The Contractor shall provide a weekly status report detailing the current activities of the project. At a minimum, the weekly status report shall include weekly activity status, risks, issues/concerns, and a high-level milestone schedule of upcoming key events.
- b. The Contractor shall develop and maintain schedule(s) detailing critical activities, tasks, and milestones. At a minimum, the schedule(s) shall detail the schedule baseline, interdependencies amongst tasks, key project milestones, estimated time to completion, critical path tasks, resource accountability and resource schedules.
- c. The Contractor shall provide a project management plan with detailed analysis and milestones for testing, risk management, training, licensing, and deploying the system to support structured change process for future updates to the system.

5. Technical and Customer Support

- a. The Contractor shall, upon OIG acceptance of the final configured software, provide software maintenance and customer support services. Any applicable customer support access code or number will be provided to allow access to submit support requests. It is expected that a transition to support meeting should take place to ensure OIG designated representatives have knowledge of the support process. The customer Support Agreement (SA) shall include, but not be limited to, the following support requirements:
 - i. Technical and customer support from the Contractor at a minimum during core business hours between 8am to 6pm Eastern Time, Monday through Friday.
 - ii. The Contractor shall support emergency technical and customer support requests outside normal business hours.
 - iii. If Contractor is directly supporting the operation and maintenance of the solution, then the Contractor shall offer at least one tier of service that meets or exceeds 95% availability during Contractor-specified normal business hours of support.

- iv. The Contractor shall offer a support service tier that includes a dedicated account manager.
- v. The solution shall provide the capability to capture and raise application events and security access attempts and send electronic notifications for identifying, submitting, and tracking incidents.
- vi. The solution shall have a documented Contractor commitment to be at least five years away from end of life and shall have at least five years of customer support available.
- vii. The Contractor shall provide, at no additional cost, and in within one business day of completing the software release schedule, a scheduled software release cycle for software updates to provide major releases, service pack releases, and vulnerability remediation patches / hotfixes.
- viii. Contractor's technical and customer support websites/portals will be hosted in the United States of America.
- ix. The Contractor shall provide live Help Desk support during the work hours of 8:00am to 6:00pm Eastern Standard Time (EST) Monday through Friday.
- x. The Contractor shall provide a self-service customer portal for identifying, submitting, and tracking issues.

6. Knowledge Transfer and Training

- a. The Contractor shall provide guidance, comprehensive knowledge transfer, and personnel training on the new COTS investigative case management system.
 - i. Knowledge Articles - The Contractor shall develop a knowledge based (or more specific role focused) articles containing details agreed upon during the technical kickoff meeting.
- b. Training Materials
 - i. The Contractor shall provide all materials to include, but not limited, recordings, slides and handouts that will be used during training sessions for review by the OIG prior to the first training session.
- c. Training Sessions
 - i. The Contractor shall provide (virtual/in-person/hybrid) user training on the new COTS investigative case management system. The specific training session content and types of training sessions will be agreed upon as part of the technical kickoff meeting.

Contract Type

The Government anticipates issuing a Firm-Fixed Price (FFP) type contract.

Administration

All communication related to any contract issues or changes should be communicated to the designated OIG COR for the contract.

Place of Performance

Most work will be performed at the Government's location. Additional work will be performed at Contractor sites. Remote Contractor work may be allowed by the COR. All remote Contractor work will be approved in writing by the COR prior to that work being performed.

The Contractor may be required by VA OIG to travel to one or more of VA OIG field offices. The Contractor will submit travel requests no less than 10 calendar days prior to expected travel to VA OIG COR, who will review. Upon written approval, the Contractor may be reimbursed. (Note: All travel is reimbursed in accordance with Federal Travel Regulations.) Travel vouchers will be submitted by the Contractor no later than three business days after the travel by the contracted personnel has returned from travel.

Period of Performance

The Government anticipates that the period of performance will be for one (1) twelve (12) month Base Period, and four (4) twelve (12) month Option Periods.

Quality Assurance

The Government shall evaluate the Contractor's performance under this contract in accordance with the Quality Assurance Surveillance Plan (QASP). This plan is primarily focused on what the Government must do to ensure that the Contractor has performed in accordance with the performance standards. It defines how the performance standards will be applied, the frequency of surveillance, and the minimum acceptable defect rate(s). The QASP shall be shared with the Contractor after award. VA OIG's evaluation of the Contractor's performance does not relieve the Contractor of its responsibility to comply with all requirements under the Contract.

Deliverables / Delivery Schedule

No.	DELIVERABLE TITLE	Format of Deliverable	Timeline/Deadline	Acceptance Criteria	VA OIG POC
1	COTS Investigative Case Management System	Product	Due no later than (NLT) 12 months from the date of contract award	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR), Contracting Officer (CO)
2	Implementation and Configuration	Services	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR), Contracting Officer (CO)
3	Configuration Plan	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
4	Configuration Control Document (CCD)	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
5	Configuration Management Tool	Product	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
6	Implementation Plan	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
7	Integrated Control Documentation	Document(s)	Due as agreed upon at the	Not accepted unless written approval is	Contracting Officer Representative (COR)

			Technical Kickoff meeting.	received from the COR	
8	Data Migration	Services	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
9	Data Migration Plan	Document(s)	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
10	Business Rules and Data Mapping	Services	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
11	Test Management Plan (TMP)	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
12	Daily Onboarding Status Report	Document	Daily (COB every weekday)	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
13	Contract Kickoff Meeting	Meeting/Document	Due 5 business days from contract award.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
14	Technical Kickoff Meeting	Meeting/Document	Due 5 business days from contract award.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)

15	Weekly Status Report	Document (MS Word document)	Weekly (COB every Friday)	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
16	Project Schedule	MS Project or other similar Project Management tool detailing the schedule, milestones, dependencies, critical path, etc.	Due 5 business days from contract award.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
17	Project Management Plan (PMP)	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
18	Support Agreement	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
19	Knowledge Articles	Document (as agreed upon at the Technical Kickoff meeting).	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
20	Training Materials	Document and other media (as agreed upon at the Technical Kickoff meeting).	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)
21	Training Sessions	Service (as agreed upon at the Technical Kickoff meeting).	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is	Contracting Officer Representative (COR)

				received from the COR	
22	A&A Documentation	Document	Due as agreed upon at the Technical Kickoff meeting.	Not accepted unless written approval is received from the COR	Contracting Officer Representative (COR)

Security Annex

1. Definitions and Confidentiality / Nondisclosure

A. Key Definitions

1. *Information* means: “any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms.” [Office of Management and Budget (OMB) Circular A-130 § 10]
2. *VA information* means: information provided by VA OIG or other VA organizations.
3. *Sensitive information* means: “any VA information that would not be released to the public by VA OIG under the Freedom of Information Act.” [OIG GM Directive 335, Revision 2, Appendix A § 1a]
4. *Personally identifiable information (PII)* means: “information that can be used to distinguish or trace an individual’s identity, either alone or when combined with other information that is linked or linkable to a specific individual. Because there are many different types of information that can be used to distinguish or trace an individual’s identity, the term PII is necessarily broad. To determine whether information is PII, the agency shall perform an assessment of the specific risk that an individual can be identified using the information with other information that is linked or linkable to the individual. In performing this assessment, it is important to recognize that information that is not PII can become PII whenever additional information becomes available – in any medium and from any source – that would make it possible to identify an individual.” [OMB M-17-12 § III-B]
5. *Record* means: “all recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government or because of the informational value of data in them” [44 U.S.C. § 3301]
6. *System of records* means: “a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual” [5 U.S.C. § 552a]
7. *Information system* means: “a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information” [44 U.S.C. § 3502]
8. *Information resources* means: “information and related resources such as personnel, equipment, funds, and information technology” [44 U.S.C. § 3502]
9. *VA system* means: any automated data processing component serviced or maintained by VA, either connected or stand-alone.
10. *Breach* means: “the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (a) a person other than an authorized user accesses or potentially accesses personally identifiable information or (b) an authorized user accesses or potentially accesses personally identifiable information for

an other-than-authorized purpose” [OMB M-17-12 § III-C]

B. Confidentiality and Nondisclosure

Contractor acknowledges, understands, and accepts the following:

1. *Presumption of sensitivity*: Contractor shall presume that all VA information and information systems accessed while performing work under this contract are sensitive and must be protected as outlined in this Security Annex.
2. *VA OIG property*: Any VA information, software, applications, information systems and hardware accessed by Contractor in the performance of work under the contract remain the sole property of OIG.
3. *Copyrights*: To the extent that any software or applications on the VA information systems are protected by copyright, Contractor will not copy or disclose them without first obtaining OIG’s prior written authorization, which will be provided only where authorized under applicable copyright law.
4. *Need to know basis*: Contractor will access, or be provided access to, the VA information, software, applications, information systems and hardware only to the extent necessary, and only for performing the work required under the contract. Contractor will take reasonable steps to ensure that it will allow only those Contractor personnel who need to see the VA materials to perform their work requirements have access. This paragraph also applies to any other VA information systems or information to which Contractor may have access to or which may be disclosed to Contractor.
5. *Restricted access*: Contractor shall not authorize anyone other than those Contractor personnel who require the information to perform work under the contract to access, disclose, modify, or destroy the information, software or applications on the VA information systems provided or accessed under the contract without OIG’s prior written authorization. To the extent permitted by law, Contractor will refer all requests or demands for production of or access to VA information and information systems, including court orders, to the OIG COR for response.
6. *Restrictions on copies*: Except as authorized under the contract, Contractor shall not make any copies of any VA information provided to Contractor by OIG, including software or applications that are not copyrighted. Any authorized copies made by Contractor shall be identified as OIG information and protected as outlined in this Security Annex.
7. *Recording, sensitivity, and disclosure of VA information*: Except to the extent necessary to perform the work under the contract, any information that Contractor learns from and about VA and OIG information and information systems shall not be recorded and such information, whether recorded or not, shall be protected as outlined in this Security Annex. Contractor may not use or disclose this information except as Contractor is permitted to use or disclose under the User Agreement/Rules of Behavior and the Nondisclosure Agreement executed in accordance with this contract.
8. *OIG Access to Information*: Contractor will provide access to all information obtained or generated under the contract to OIG employees as designated by the OIG COR.
9. *Retention and return of information, software and equipment*: Upon completion or termination of the contract for any reason, Contractor shall as soon as practicable, deliver all non-public (that is, not open to, shared with or otherwise made available to the public) VA information, copies made of VA information, software and equipment, in its possession, to OIG. Contractor shall not retain any copies of any VA sensitive/non-public

information, software, or equipment unless authorized by the OIG COR or by the OIG Information Security Division (ISD-53I).

10. *Restricted disclosure*: Disclosure of VA information to persons other than in the performance of the contract is authorized in only two situations: (a) pursuant to an order of a court of competent jurisdiction; or (b) with OIG's prior written authorization. Prior to any disclosure pursuant to a court order, Contractor shall promptly notify OIG and provide OIG with a copy by fax or email, whichever is faster, and notify by telephone the OIG COR in advance that it will be receiving such notices. The notice under this provision will include the following information to the extent that Contractor knows it, if it does not show on the face of the court order: the records to be disclosed pursuant to the order, to whom, where and when, for what purpose, and any other information that Contractor reasonably believes is relevant to the disclosure. To clarify this requirement, Contractor shall not disclose any VA information without prior consent from OIG.
11. *Notifications of unauthorized actions*: Contractor shall promptly, within one hour of confirmation of an unauthorized action by Contractor or Contractor personnel, notify the OIG COR and OIG ISD (53I) of any access, disclosure, disposition, or destruction of VA information and information systems not authorized under the contract. To the extent known, Contractor will notify the OIG COR and OIG ISD (53I) of the information improperly disclosed, to whom, how, when, the reason for the access, disclosure, disposition or destruction, and any other relevant information or information requested by the OIG.
12. *Law enforcement and legal proceedings*: Contractor will cooperate with OIG and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any unauthorized access, disclosure, disposition or destruction of VA information or property. Contractor will also cooperate with VA in any civil litigation to recover VA information or property, to obtain monetary or other compensation for a third party, or to obtain injunctive relief against any third party who accessed, modified, disclosed or destroyed VA information and information systems except as explicitly authorized under the contract.

2. Personnel Security

A. Mandatory VA OIG User Agreement/Rules of Behavior and Nondisclosure Agreement

1. *General rule*: Every individual Contractor personnel who will access VA information or VA information systems under the contract shall complete a VA OIG User Agreement/Rules of Behavior (UA/RoB) and Nondisclosure Agreement (NDA). The OIG ISD (53I) must accept the submitted UA/RoB and NDA before any Contractor personnel may obtain access or start work. The OIG Information Security Division (53I) determines the acceptability of submitted UA/RoBs and NDAs.
2. *Provide Email Contact*: Contractor shall provide the email addresses for each individual Contractor personnel that must complete this requirement. The email address may be a work or a personal email address for this specific requirement. If a Contractor official is coordinating the return of UAs/RoBs and NDAs, that official must first receive approval and instructions from the OIG ISD (53I) before proceeding.
3. *Sign UA/RoB*: Each individual Contractor personnel who will access VA information or VA

information systems under the contract shall complete the following tasks prior to OIG authorizing such access:

- a. Read the current VA OIG UA/RoB provided by the OIG ISD (53I),
 - b. Complete and sign it per the instructions provided by the OIG ISD (53I), then
 - c. Return the (electronically) signed and completed UA/RoB to the OIG ISD (53I) as directed.
4. *Sign NDA:* Each individual Contractor personnel accessing VA or VA OIG information or information systems under the contract shall complete the following tasks prior to OIG authorizing such access:
- a. Read the current VA OIG NDA provided by the OIG ISD (53I),
 - b. Complete and sign it per the instructions provided by the OIG ISD (53I), then
 - c. Return the (electronically) signed and completed NDA to the OIG ISD (53I) as directed).
5. *Sign annually:* Should this contract be extended, each individual Contractor personnel shall sign the UA/RoB and NDA annually and return it to the OIG ISD (53I) prior to (continuing) accessing VA information or information systems and starting work, for each year of the contract.
6. *Sign individually:* Each individual Contractor personnel shall individually sign the UA/RoB and NDA.
7. *Non-Repudiation:* Each individual Contractor personnel shall provide a UA/RoB and NDA that meets or exceeds the non-repudiation requirements specified by the OIG ISD (53I). Contractor personnel shall be timely in providing corrected UAs/RoBs or NDAs as directed by the OIG ISD (53I) and in providing additional proofing documentation as requested.

Digitally-signed (electronically-signed) UAs/RoBs and NDAs must be submitted to OIG as a saved file, not printed out or scanned. Digital signatures using a non-repudiation certificate that is created by either a public certificate authority (CA) or use an in-house CA can be accepted if the OIG ISD (53I) determines the signature validates; however, the CA must appear on one of the Federal Bridge Trust List lists (<https://www.idmanagement.gov/trust-services/>). If using an in-house CA, the OIG ISD (53I) must pre-approve the Contractor's CA and certificates proposed for digital signatures.

B. Information Security and Privacy Awareness Training

1. *General requirement:* Contractor personnel shall complete all security, privacy, and other training required by OIG.
 - a. *When due:* Contractor personnel shall complete the specified information security and privacy awareness training **before** obtaining access to VA information, data, or IT systems and starting work under this contract.
 - b. *Additional requirements:* Additional training may be required if policy changes. This requirement is in addition to any other training that may be required of Contractor. OIG will identify the training to be taken and the method for taking it.

2. *Specific instructions.*

a. *Complete courses before starting work:* Contractor personnel shall complete the VA information security and privacy awareness course (TMS course 10176) and the VA HIPAA privacy awareness courses (TMS course 10203) prior to obtaining access to VA information, data, and IT systems and beginning work. No access to VA information, data, and IT systems will be authorized until evidence of course completions are registered in the VA TMS system.

b. *Courses required for administrator/elevated access:* Contractor personnel shall complete the VA Information Security and Privacy Role-Based Training for IT Specialists course (TMS Course 3197) along with any other OIG-specified training prior to being granted any administrator or elevated-privilege account or access. Contractor personnel granted access to fulfill the EMS to CMS migration shall complete this requirement.

c. *Provide certificates to OIG:* Contractors shall provide copies of the certifications of completion to the COR or designee and must maintain copies of the completion certificates for the life of this contract. OIG will accept copies, faxes, .pdf image files, etc. of training certificates.

d. *Complete annually:* Contractor shall annually complete the information security and privacy awareness courses, as designated by OIG. Contractor personnel shall individually complete training prior to accessing VA information, data, and IT systems and starting work, for each year of the contract.

e. *Use the internet:* OIG will provide the instructions for completing the designated information security, privacy awareness, and HIPAA courses for this contract using VA's TMS system, unless OIG directs Contractor to use other methods. Contractor personnel may register and complete the courses using personal or Contractor-provided equipment.

3. *Applicability:* These requirements extend to personnel such as owners, concurring partners, internal or external peer review teams, specialists, and individuals with whom Contractor consults if they access sensitive information or non-public information systems under this contract. Contractor personnel may be required to complete information security and privacy training as specified by the OIG ISD (53I) prior to being granted access to other non-public information systems.

C. **Initial Background Check**

1. *Requirement:* Contractor personnel shall pass an initial background check completed by OIG before beginning work. OIG facilitates an initial background check on each individual Contractor personnel. To complete this background check, Contractor personnel shall complete the following requirements.

2. *Provide information:* Each individual Contractor personnel shall provide the following information about himself/herself to the OIG COR:

- a. Full legal name (first, middle, and last name; and prefixes and suffixes, if applicable)
- b. Other names known by, such as maiden name, any alias, nicknames, etc.
- c. Other names used

- d. Social security number
- e. Gender
- f. Date of birth (month, day, year)
- g. Place of birth (zip, city, and state or name of foreign country)
- h. Citizenship
- i. Current home address
- j. Current phone numbers applicant can be reached at
- k. Current Work address, supervisor name, and supervisor phone number
- l. Current Work email address
- m. Employment dates at Contractor
- n. Previous employment history including City and State (7 years)
- o. Previous home address history including City and State (7 years)
- p. Currently active background investigation and/or suitability determination
- q. OIG COR/Sponsor and OIG Division assigned to for this contract
- r. Job title and position under this contract. The information should describe the:
 - (1) Level of responsibility in the firm (e.g., Partner, Manager, etc.),
 - (2) Division assigned to within the firm, and
 - (3) Nature of the work assignment (e.g., Financial or IT Auditor, Penetration Testing Specialist, Actuary, Economist, Data Specialist, etc.)

Should OIG require additional information for the performance of background checks, Contractor will work with OIG to obtain such additional information. Contractor shall provide OIG any additional requested information within two (2) business days.

3. *Transmit information securely:* Contractor's personnel security officer shall securely submit the information gathered in Paragraph 2.C.2 to OIG in a format accepted or designated by OIG. The Contractor's personnel security officer may provide OIG hard copies or use secure electronic submission. For electronic transmission, Contractor will coordinate with the OIG COR, OIG ISD (53I), or OIG personnel security and suitability office (51S) on acceptable methods.
4. *Receive authorization to start:* OIG will provide notice to Contractor of individuals approved to start work and access VA information or VA information systems. No Contractor personnel shall commence work without OIG approval.
5. *Annual updates:* Should this contract be extended, Contractor personnel shall follow the above procedures and obtain approval from OIG prior to accessing VA information or information systems and starting work, for each year of the contract. For team members who remain continuously on the engagement, OIG will notify Contractor each year whether the required information needs to be resubmitted.
6. *Timing:* Contractor shall incorporate into its project schedule sufficient time for OIG to complete initial background checks before members are scheduled to begin work. The initial background check generally takes three to five business days to complete.
7. *Eligibility:* All Contractor personnel must be [a] U.S. Citizens OR [b] a lawful permanent resident (green card) for at least five years (three if seeking naturalization as a spouse of a citizen) and also seeking citizenship.

D. Suitability Determination - Background Check

1. *Requirement:* Contractor personnel who will be granted direct access to OIG's EMS system (or direct access to any other OIG or VA system) must undergo a pre-employment background investigation prior to work. Direct access does not include VA Entra/Active Directory accounts if those accounts are solely for PIV issuance or solely for access to the Contractor's solution. Direct access does not include access to OIG's Kiteworks solution or collaboration with Contractor email addresses. Once Contractor personnel have been approved by OIG Personnel Security & Suitability (51S) staff, they must undergo a suitability background investigation and be favorably adjudicated while working on a conditional basis. These requirements extend to individuals with whom Contractor is authorized to consult with if sensitive VA or OIG information is shared. Contractor shall exercise good planning to avoid exception requests. OIG (51S) staff make suitability determinations for all Contractor personnel in accordance with OIG and VA policy and Defense Counterintelligence and Security Agency (DCSA) regulations for Public Trust positions.
2. *Investigation type:* OIG requires suitability determinations at a minimum as follows:

<i>Access or Deliverable</i>	<i>Public Trust Investigation Type</i>	<i>Requirement</i>
Direct access to the legacy EMS system to fulfill the migration deliverables	DCSA Tier 4	Completed at least a favorably adjudicated Tier 4 Investigation (suitability determination)
All other direct access not exempted by Security Annex Paragraph 2.D.1	DCSA Tier 2S	Completed at least a favorably adjudicated Tier 2S Investigation (suitability determination)

3. ***Obtaining the investigation:*** Contractor shall follow instructions from OIG on how to obtain the required background investigation. OIG currently uses the Bureau of Fiscal Services (BFS) in managing the background investigation process. Contractor shall work with BFS as directed by OIG. The current process for obtaining the appropriate background investigation and adjudication is as follows:

a. For individuals with background investigations/suitability determinations completed by another entity at the appropriate levels.

OIG at its discretion and at Contractor's request may accept background investigations performed by other entities under the following conditions:

- (1) Contractor shall indicate the type of investigation, the authority or agency who conducted the review, and the date of the investigation.
- (2) The investigative history for the required level of investigation must be maintained in OPM's Clearance Verification System (CVS), which is a subsection of OPM's Personnel Investigation Processing System (PIPS).
- (3) Should Contractor have used a Vendor other than OPM or DCSA to conduct investigations, the investigative company must be certified with either OPM or DCSA.
- (4) OIG may, at its discretion, accept national security clearance investigations that are equivalent to the public trust investigations required under this contract.
- (5) OIG will make its own suitability determination based on the investigative history and notify Contractor or the OIG COR whether the individual is authorized to commence or continue work under the contract.

b. For individuals without background investigations/suitability determinations at the required level.

- (1) Contractor shall notify OIG of those staff requiring new or additional background investigations.
- (2) OIG will initiate the appropriate investigation through the BFS, which will coordinate the investigation with DCSA.
- (3) Contractor shall coordinate investigation requirements with OIG and provide investigation requests in a format agreed to or designated by OIG.
- (4) Under current practice, 51S will provide Contractor personnel access to DCSA's NBIS eApp (electronic application) and NBIS Agency (for Security Managers), which collects information required to perform the investigation.

Contractor personnel shall enter the requested information into eApp promptly, but no later than five (5) days after access to eApp is granted unless directed otherwise.

The NBIS eApp website is located at:

<https://www.dcsa.mil/Systems-Applications/National-Background-Investigation-Services-NBIS/>

(5) Contractor personnel shall coordinate with OIG to obtain fingerprinting through VA security services, as required. VA security services transmit fingerprints to DCSA and USAccess.

(6) OIG will notify Contractor whether the individual is authorized to commence or continue work under the contract.

c. Background investigation is currently underway by another entity: Contractor will follow OIG's instructions.

1. *Timing:* Contractor shall initiate the investigation process described above as soon as practicable to avoid delays in work. We strongly encourage Contractor to obtain investigations for backup personnel to ensure adequate staff coverage throughout the contract cycle. Whenever new personnel are hired or considered for this assignment, Contractor should expedite security paperwork to minimize the waiting period before staff is authorized to access VA information, data or IT systems and start work.

2. *Conditional approval:* Currently, OIG grants conditional approval for Contractor personnel to access VA information, data, and IT systems before the suitability determination is complete and after completion of a successful initial background check and Special Agency Check (SAC). Continued access is contingent upon successful completion of a suitability determination and remains at the discretion of OIG. OIG reserves the right to require completion of a suitability determination before it grants access to Contractor personnel.

3. *Life of background investigation:* Public trust background investigations and adjudications currently expire after five years for a Tier 2/Tier 4 investigation. Contractor must ensure that its personnel maintain a current, valid investigation when performing work under this contract.

At its discretion, BFS and OIG may allow a reinvestigation to be performed upon expiration of a Tier 2 or Tier 4 adjudication.

4. *Investigation costs:* Contractor is responsible for all costs associated with obtaining and updating the required background investigations for suitability determinations. Currently, DCSA, BFS, and VA security services charge OIG for their services. Contractor shall therefore reimburse OIG for these costs in a manner directed by OIG. That method currently is:

a. OIG will periodically issue "Contractor chargebacks".

b. Contractor shall reimburse OIG by reducing its invoiced amount to OIG for the investigation charges. Contractor's invoice shall identify the reimbursement adjustment through an explicit line item.

c. Contractor shall reimburse OIG within 30 days of bill receipt, unless otherwise agreed to by OIG due to timing of the Contractor's next invoice.

5. *Non-U.S. citizens:* Contractor personnel who do not have U.S. citizenship

shall have legal authorization to work in the United States. Contractor shall provide evidence of such authorization, including having the proposed Contractor personnel present himself/herself to OIG with the necessary I-9 documentation (see <https://www.uscis.gov/i-9-central> for the I-9 form).

E. On-Site Access; Personal Identity Verification (PIV) Card, Non-PIV card, and Badging

1. *Site visit access:* Contractor shall coordinate physical access requirements with the OIG COR. Contractor personnel will be escorted at all times while at VA or OIG locations unless issued a VA PIV plus approved by the OIG COR. Contractor personnel will follow OIG instructions for sites that have specific security requirements (e.g., data centers).
2. *VA-issued Personal Identity Verification (PIV) badge:* Contractor personnel shall apply for a PIV card through OIG. OIG will not accept applications for PIV cards until the initial background check is complete and the appropriate background investigation has, at minimum, been initiated for PIV cards. OIG determines the type of PIV issued.
 - a. *Application process.* Unless OIG directs otherwise:
 - (1) *Contact OIG:* Contractor personnel shall complete the necessary application documentation for a PIV card according to OIG's direction. Instructions will be provided either from "OIG.PIVRequest@va.gov" or from the OIG COR.
 - (2) *VA Badging Office:* OIG will provide instructions for working with VA's PIV badging offices to obtain a PIV card. Currently the process is:
 - a) A VA or USAccess badging office will take the Contractor personnel's picture and fingerprints. Fingerprints are in addition to any fingerprinting that may be required for a background investigation. The office requires two forms of acceptable identification and a completed application.
 - b) Contractor personnel must make a second trip to the VA or USAccess badging office to pick up the PIV card at a later date.

The VA has offices throughout the country that provide PIV issuance services (see https://www.osp.va.gov/Badge_Office_Locations.asp). USAccess lists VA and non-VA locations (<https://portal.usaccess.gsa.gov/scheduler/select-agency>). OIG will work with Contractor to determine the best location to use for the PIV process.
 - b. *Timing:* The PIV badging process can take several days, so Contractor should begin the process well before an individual needs a PIV card.
3. *VA PIV card and badge return:* Contractor shall collect all VA PIV cards and other badges from Contractor personnel who leave the contract or "roll-off" (e.g., suspend work on the contract for a period of time, such as at the end of a contract phase) within 4 days of departure or as specified by OIG. Contractor shall return the badges to OIG for safekeeping. Contractor shall periodically provide OIG (or upon request) a schedule of Contractor personnel and the timing of their anticipated departure or "roll-off." Contractor shall follow any other OIG instructions

on badge return, safekeeping, and reporting.

4. *Wearing badges:* Contractor personnel shall wear a VA-provided badge/credential while at any VA facility or location. Contractor personnel shall also carry their employer's identification badge (if provided) or a U.S. state-issued driver's license on their person at all times.

VA-provided badges/credentials shall be displayed at all times while at a VA facility inside the provided electromagnetically opaque sleeve and shall be worn and visible, above the waist on the outermost garment with the photo side visible. The only exception is where displaying the credential may cause a safety risk to a Cardholder, patient, or other individual. The Cardholder shall follow appropriate occupational safety requirements including but not limited to when conducting certain medical procedures or patient interactions or when working around machinery with moving parts.

5. *PIV card and badging costs:* Contractor is responsible for any costs associated with obtaining badges for its personnel.
6. *On-Site Access to Sensitive Information:* Access provided under §2.E of this Security Annex to OIG or VA locations that are not accessible by the public along with all sensitive information observable or heard in those non-public locations does not authorize Contractor to create, capture, record, or retain any sensitive information unless using OIG-authorized IT inventory provided under §3.A of this Security Annex.

F. Keys and Physical Access Devices

Contractor shall promptly (but no more than within 3 calendar days) return keys, access cards, access fobs, etc., provided by OIG or VA. Contractor is responsible for reimbursing OIG or VA for costs associated with failure to return access devices.

G. Departure Notifications

1. *Termination or unplanned departure:* Contractor shall notify the OIG contracting officer (CO), COR, and ISD (53I) **immediately**, but not more than one hour after discovery, of any termination or unplanned departure of personnel and provide written confirmation to the OIG COR within one calendar day.
2. *Planned departures:* Contractor shall notify the OIG CO, COR, and ISD (53I) with written confirmation of planned staff departures or planned removal from work under this contract within 15 calendar days of planned departure or removal.
3. *Departure confirmation:* Contractor shall provide the OIG COR with written confirmation within three calendar days confirming that the planned departures have occurred.
4. *Equipment of departed staff:* Contractor shall coordinate with the OIG COR on the reassignment or return of any OIG approved equipment from personnel leaving the engagement. No equipment shall be released from the contract without final sanitization approval from the OIG ISD (53I).

3. Operational and Technical Security Controls

A. Contractor Access to and Use of Equipment, Devices, or Media for Contract Work

1. *OIG issued equipment:* For this contract, OIG will issue equipment, devices, or media (collectively referred to as "IT inventory") for work under this contract. OIG will issue one OIG laptop per approved Contractor personnel working at the OIG location or directly on OIG-provided resources or systems. The laptop will be pre-configured by OIG. OIG currently provides Windows 11 and VA-licensed Office 365 applications (Word, Excel, Access, and Outlook). OIG will provide up to five (5) licenses of Visio. OIG may provision virtual machines at OIG's discretion. OIG may set up restricted viewer and online editing within OIG's Kiteworks solution for select Contractor personnel in lieu of providing OIG inventory and OIG-managed @va.gov accounts.
2. *VA-provided resources:* If Contractor personnel already have VA-issued inventory, VA-issued PIV or non-PIV cards, VA-issued two-factor tokens/authenticators, or VA-provided Active Directory accounts, Contractor shall declare those to the OIG COR and OIG ISD (53I). OIG ISD (53I) will determine whether (a) to authorize the previously issued VA resources for this contract or (b) to require Contractor to close existing VA accounts and return VA inventory in exchange for OIG-provided accounts and inventory. Contractor shall presume that any direct access to OIG-sensitive information or systems will require Contractor personnel to only use OIG-provided accounts and inventory.
3. *Work products:* Work products (deliverables, notes, etc.) that are **not** sensitive information may be created, maintained, and stored on Contractor's IT inventory. At OIG's discretion, OIG may provide use of Kiteworks for secure exchanges of files and messages. All sensitive information shall be created and maintained only on OIG IT inventory. If the solution is a Contractor-managed FedRAMP authorized solution, Contractor may maintain sensitive information within the OIG-authorized boundary of the FedRAMP solution as directed by OIG (including sensitive information in support/help desk systems). OIG generally provides Microsoft SharePoint workspace, Microsoft file server space, and a Kiteworks FedRAMP site for sensitive information.
4. *Authorization required:* Contractor shall not use any IT inventory under this contract if it has not been provided by the OIG or explicitly authorized by the OIG COR with concurrence from OIG ISD (53I) or OIG CIO.
5. *Allowed accounts:* Contractor personnel shall only access OIG-provided computers and use accounts set up by OIG IT staff. OIG ISD (53I) will determine then the OIG COR will direct Contractor personnel to use either the @va.gov email address provided or use an authorized Contractor email address to access OIG's Kiteworks solution. Contractor personnel suitability/background check information and correspondence directly pertaining to the contract itself may be sent from Contractor's email addresses (directly or via OIG Kiteworks).
6. *Transporting and remote access:* Contractor must obtain explicit authorization from the OIG COR prior to removing the OIG-provided computer from the OIG work site for use or storage at the Contractor's office or any proposed telework location. Contractor personnel must receive approval from the OIG COR to use

VA's RESCUE VPN remote access service. Other VA remote access services are not authorized unless explicitly authorized by OIG ISD (53I) for directly fulfilling contract deliverables. The OIG COR determines the duration of all authorizations and approvals under this section. Contractor is prohibited from transporting or shipping the OIG-provided laptop or any other OIG-provided inventory or sensitive information outside of the United States of America.

7. *Reconnection requirements:* Contractor will connect OIG-provided laptops to VA's internal network (either directly or via VA's RESCUE VPN service) no less than every 30 days and leave connected for a minimum of four hours to ensure registration, patching and monitoring of the laptops. Travel expenses to transport an OIG-provided laptop to an OIG or VA location due to noncompliance with this requirement will not be reimbursed.
8. *Connections:* Contractor may connect OIG-provided laptops to Contractor-provided Internet service while the laptops are located in the Contractor's office when connecting to VA VPN. Contractor must obtain explicit authorization from the OIG COR or OIG ISD (53I) prior to connecting the OIG-provided equipment to any other network (e.g., hotel WiFi or home/personal network). OIG-provided equipment must be connected to VA RESCUE VPN immediately after connecting to hotel or other public WiFi.
9. *Maintenance impact:* Contractor accepts that the OIG-provided laptops are continually maintained, which may result in software being updated or replaced. This includes but is not limited to operating system and components, Microsoft Office applications, VPN software, and so forth. Contractor understands and accepts that VA or OIG required changes may have an impact on Contractor's use of the laptops.
10. *Inspections:* Contractor shall provide all devices to be used under this contract to the OIG ISD (53I) for inspection upon demand. Inspections shall occur at OIG's discretion, at regular intervals thereafter, and upon demand by the OIG ISD (53I). OIG will periodically inspect devices for compliance with all terms and requirements under this contract. OIG, at its discretion, may conduct on-site surprise inspections of laptops and other IT inventory.
11. *Changes:* Contractor shall not install, modify, or delete any software on the computer provided by OIG or VA, or on any OIG or VA servers. Contractor may submit requests to the OIG COR for additional software installations if needed to fulfill the contract -- the installation of that software will require pre-approval from the OIG ISD (53I) then subsequently will be at the discretion of OIG IT staff. Contractor shall not make any hardware changes. Contractor shall provide all licenses at Contractor's expense for any additional software they deem necessary to complete the work under this contract.
12. *Testing platforms:* Contractor may establish at Contractor's cost a test lab or environment for assessing Deliverables solutions. Contractor shall not import, process, or store any sensitive OIG information (including sensitive security configurations or accounts) on Contractor's test environment. Use of a VA-hosted test lab or environment outside of OIG control requires explicit OIG Chief Information Officer (CIO) pre-approval.

13. *Non-OIG IT inventory:* Contractor acknowledges and accepts that if non-OIG-provided devices or media are proposed for use, it will be subject to the same requirements as OIG owned devices. The OIG ISD (53I) may require additional security measures be met to the OIG ISD's satisfaction including, but not limited to, device configuration, device monitoring, device recovery, infrastructure protection, and device/media sanitization before authorizing those devices or media. Sensitive information shall never be transmitted to, accessed on, or stored on non-OIG equipment including when consulting with other Contractor personnel that are not approved and working under the contract.
14. *Non-OIG connections:* Contractor is prohibited from connecting any type of equipment, devices, or media that has not been (a) provided by OIG or (b) pre-approved by the OIG ISD (53I) to any non-public VA or non-public OIG systems without explicit OIG CIO or OIG ISD (53I) authorization. Cameras, voice recorders, portable storage devices (such as USB/thumb drives, external hard drives), or removable media (such as compact discs {CDs}, digital versatile discs {DVDs}) shall not be used to transmit or store sensitive VA or OIG information unless explicitly authorized by the OIG ISD (53I). Portable storage devices (such as USB/thumb drives, external hard drives) are prohibited from being connected to any OIG or VA system unless directly inspected by then explicitly authorized by the OIG ISD (53I).
15. *Hard copy media:* Hard copy media, including but not limited to printing, of any sensitive VA or OIG information is prohibited unless explicitly authorized by the OIG COR, with concurrence from OIG ISD (53I) or OIG CIO.
16. *Phones:* Contractor personnel may be permitted to use OIG or VA landline phones on a case-by-case basis but will limit long-distance/toll calls to essential business only. Contractor may use a personal or Contractor-furnished landline or cellular phone for work under this contract as long as the contents of phone conversations are never recorded on any non-OIG system. Contractor personnel will remove OIG contact information from personal or Contractor-furnished phones upon request by the OIG COR, OIG ISD (53I), or the OIG contact associated with the number.

B. File, Video, and Collaboration Services

1. *Blocked sites:* VA generally blocks file sharing websites such as box.com, dropbox.com, and similar sites. VA may block video streaming hosting sites and collaborative hosting sites. Contractor shall not be able to use any sites blocked by VA for work or for deliverables under this contract. Contractor accepts that OIG cannot provide an exhaustive list of sites that VA blocks.
2. *Sharing sites:* OIG maintains its own Accellion Kiteworks file sharing and messaging site along with a Webex.com site. Contractor will coordinate with the COR to use OIG's Kiteworks, Teams, or Webex capabilities to meet contract deliverables, including transmitting files or messages. Contractor will provide requests to the OIG COR no less than two full business days before OIG's Kiteworks or Webex access is required. Contractor's email system and IT environment must allow incoming emails from "vaoig-noreply@kiteworks.com" to

use OIG's Kiteworks system.

3. *VA provided applications:* VA-provided or Contractor-hosted Microsoft Teams are authorized. OIG-provided or Contractor-hosted WebEx meetings are authorized. Other VA-provided services including but not limited to Office 365 applications are prohibited without OIG ISD (53I) or OIG CIO approval.
4. *Collaboration Access to Sensitive Information:* Access provided under §3.B of this Security Annex to OIG or VA systems that are not accessible by the public along with all sensitive information communicated through such services does not authorize Contractor to create, capture, record, or retain any sensitive information unless using OIG-authorized IT inventory provided under §3.A of this Security Annex.
5. *Collaboration Access Restrictions:* Contractor personnel are prohibited from accessing or joining any collaboration sites or sessions from outside the United States of America without explicit pre-authorization from the OIG COR.

C. Electronic Mail (Email)

1. *Contractor email:* Contractor personnel will use Contractor's email service for all email communications under this contract. Use of personal email accounts is prohibited. OIG's Kiteworks solution can be used if Contractor does not have a dedicated email service.
2. *Email size:* VA limits the total size of individual emails. Proposed exchanges of messages + files greater than 10MB per email will use OIG's Kiteworks solution.
3. *.Zip and file attachments:* VA blocks and deletes emails that contain .zip file attachments. Contractor will not attach a .zip file to any email sent to OIG. OIG's Kiteworks solution allows transfer of .zip files.
4. *Sensitive information in emails:* The Contractor shall not include any sensitive data in calendar invites, emails, or invitations to meetings or collaborations. Even if OIG employees unintentionally provide sensitive information through any other method, the Contractor shall exclusively use OIG's Kiteworks secure information exchange solution for any messages that might contain such information.

D. Assessment and Authorization (A&A)

1. *Cloud-Based Solutions / Components:* Cloud-based solutions must comply with OMB M-24-15.

VAOIG staff shall have full access to all FedRAMP documentation and artifacts. VAOIG staff usually requests this access directly via the FedRAMP.gov points of contact.

2. *Hardware or software:* Hardware or software proposed under the contract must conform with Federal security and privacy requirements including but not limited to

PIV-based or other VA-supported two factor authentication, FIPS 140-2 of 140-3 encryption certification, configuration, and continuous monitoring.

3. *A&A documentation support:* Contractor shall provide authority to operate (ATO) documentation and complete A&A artifacts including but not limited to:
 - System Security Plan (SSP)
 - FIPS 199 Categorization Worksheet
 - Configuration Management Plan (CMP)
 - Contingency Plan (CP)
 - Incident Response (IRP)
 - Privacy Impact Assessment (PIA)
 - Privacy Threshold Assessment (PTA)
 - Rules of Behavior
 - System Boundary Diagrams (networking, data flow, authentication, etc.)
 - Customer Responsibility Matrix/List
 - Security Assessment (including direct access for assessors)

E. Reporting Security Incidents

1. *Reporting incidents:* Contractor shall report to the OIG COR and to the OIG ISOD (531) any security incidents or allegations of violations by Contractor personnel as soon as known, but not more than one hour after discovery. Contractor shall provide a written report within two business days or sooner, as required by the OIG.

Contractors must report all information security incidents (ISI) involving VA OIG systems or information to the designated VA OIG Information Security Officer (ISO) without regards on the impact level.

- a. Contractors must report any and all ISI involving information technology (IT) systems and Controlled Unclassified Information (CUI) immediately upon becoming aware of the ISI but no later than 60 minutes after becoming aware of the ISI, **regardless of day or time; regardless of internal investigation, evaluation, or confirmation of procedures or activities; and regardless of whether the ISI is suspected, known, or determined to involve IT systems operated in support of this contract.**
 - b. Contractors reporting an ISI to the ISO by email or phone must copy the Contracting Officer (CO) and/or Contracting Officer's Representative (COR) if possible; but if not, must notify the CO or COR immediately after reporting to the ISO.
2. *Reporting within VA facilities:* When visiting a VA facility or any facility required under the contract, Contractor shall also report any security incidents as soon as known, but not more than one hour after discovery, to OIG representative on site or the OIG official coordinating the site visit.
 3. *Security incident:* A security incident is a violation of computer security policies, acceptable use policies, or standard security practices identified in the contract, including but not limited to:

- a. Unauthorized access to, or disclosure of, VA information.
 - b. Unauthorized modification or destruction of VA information.
 - c. Reduced, interrupted, or terminated information processing capability.
 - d. Introduction of malicious programs or virus activity.
 - e. Degradation or loss of VA information system and/or confidentiality, integrity, or availability. This includes, but is not limited to, compromised passwords and failure to encrypt information when emailing or storing it.
 - f. Loss, theft, damage, or destruction of a VA asset or IT resource, or an individual Contractor personnel's asset or IT resource that contains VA information, for example, loss of a laptop.
4. *Confiscation:* Contractor and Contractor personnel accept that OIG has the authority to confiscate any Contractor equipment that either (1) store or transmit sensitive VA information but do not meet the OIG's security requirements, (2) connect to non-public VA systems but do not meet the OIG's security requirements, (3) are unauthorized in OIG or VA non-public areas, or (4) are used for illegal activities.
5. *Reporting:* The parties acknowledge that VA has special reporting requirements for security violations under the "Veterans Benefits, Health Care, and Information Technology Act of 2006," Pub. L. No. 109-461 and, if necessary, is required to provide credit protection services if sensitive personal information has been compromised. OMB Memorandum 17-12, "Preparing for and Responding to a Breach of Personally Identifiable Information" also establishes reporting requirements for Government agencies.

In the event of an incident:

- a. The Contractor must provide full access and cooperation for all activities determined by CO or COR to be required to ensure an effective review and response to protect VA OIG's Information and Information Systems operated in support of this contract.
- b. The Contractor must promptly respond to all requests by the CO or COR for ISI and system-related information, including but not limited to disk images, log files, event information, and any other information determined by VA OIG to be required for a rapid but comprehensive technical and forensic review.
- c. VA OIG, at its sole discretion, may obtain the assistance of Federal agencies and/or third-party firms to aid in ISI Review and Response activities.
- d. The Contractor must not make any determinations related to an ISI associated with Information Systems or Information maintained by the Contractor in support of the activities authorized by this contract, including determinations related to notification of affected individuals and/or Federal agencies (except reporting criminal activity to Law Enforcement Organizations) and offering of services, such as credit monitoring.

- e. The Contractor must not conduct any internal ISI-related review or response activities that could modify or eliminate any existing technical configuration or information or forensic technical evidence existing at the time of the ISI without approval from the VA OIG Chief Information Officer (CIO) through the CO or COR.
- f. All determinations related to an ISI associated with Information Systems or Information maintained by the Contractor in support of the activities authorized by this contract will be made only by the VA OIG CIO through the CO or COR.

F. Liability for Damages or Corrective Actions

Contractor liability: Contractor will be responsible for the actions of all individuals provided to work for the VA under this contract. As an independent Contractor, Contractor shall be responsible for any costs incurred by OIG as a result of Contractor negligence or corrective actions in response to liability claims. For example, OIG may incur costs to perform credit monitoring services or notifying individuals of inappropriate disclosure of personal information. Furthermore, in the event that damages arise from work performed by Contractor personnel under this contract, Contractor shall be responsible for all resources necessary to remedy the incident.

G. Liquidated Damages for Breach

1. *Sensitive personal information:* Consistent with the requirements of 38 U.S.C. §5725, a contract may require access to sensitive personal information. If so, the Contractor is liable to VA for liquidated damages in the event of a breach or privacy incident involving any sensitive personal information the Contractor processes or maintains under this contract.
2. *Notice:* The Contractor shall provide notice to OIG of a “security incident” as set forth in the Security Annex under “Reporting Security Incidents.” Upon such notification, the OIG will conduct an independent risk analysis of the breach to determine the level of risk associated with the breach for the potential misuse of any sensitive personal information involved in the breach. Contractor shall fully cooperate with the entity performing the risk analysis. A report of a breach by itself is not interpreted as evidence that the Contractor did not provide adequate safeguards. Failure to cooperate may be deemed a material breach and grounds for contract termination.
3. *Risk analysis:* Each risk analysis shall address all relevant information concerning the breach, including the following:
 - a. Nature of the event (loss, theft, unauthorized access)
 - b. Description of the event, including:
 - (1) Date of occurrence

- (2) Data elements involved, including any personally identifiable information (PII), such as full name, social security number, date of birth, home address, account number, disability code
- c. Number of individuals affected or potentially affected
- d. Names of individuals or groups affected or potentially affected
- e. Ease of logical access to the lost, stolen or improperly accessed information in light of the degree of protection for the information (example: unencrypted, plain text)
- f. Amount of time the information has been out of VA control
- g. The likelihood that the sensitive personal information will or has been compromised (made accessible to and usable by unauthorized persons)
- h. Known misuses of information containing sensitive personal information, if any
- i. Assessment of the potential harm to the affected individuals
- j. Breach analysis as outlined in VA Handbook 6500.2, "Management of Data Breaches Involving Sensitive Personal Information (SPI)," as appropriate
- k. Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive personal information that may have been compromised
- 4. *Liquidated damages*: Based on the determinations of the independent risk analysis, Contractor shall be responsible for paying to VAOIG liquidated damages in the amount of \$37.50 per affected individual to cover the cost of providing credit protection services to affected individuals consisting of the following:
 - a. Notification
 - b. One year of credit monitoring services consisting of automatic daily monitoring of at least three relevant credit bureau reports
 - c. Breach analysis
 - d. Fraud resolution services, including writing dispute letters, initiating fraud alerts and credit freezes, to assist affected individuals to bring matters to resolution
 - e. One year of identity theft insurance with \$20,000.00 coverage at \$0 deductible
 - f. Necessary legal expenses the subjects may incur to repair falsified or damaged credit records, histories, or financial affairs

H. Audit and Investigation

- 1. *Audit or investigation*: To the extent permitted by law, Contractor will cooperate in any audit or investigation related to this contract and project conducted by OIG.
- 2. *Cooperation*: Contractor shall cooperate with all audits, inspections, investigations, or other reviews conducted by or on behalf of OIG as described in

Paragraph H.1 including, but not limited to, prompt disclosure to authorized officials of information and records requested in connection with any audit, inspection, investigation, or review, and making employees of Contractor available for interview by auditors, inspectors, and investigators upon request.

3. *Security incident:* In the event of any security incident as defined in Paragraph 3.E.3 of this annex, including but not limited to those constituting an actual or potential threat or hazard to the integrity, availability, or confidentiality of VA information in the possession or under the control of Contractor or to the function of information systems operated by Contractor in the performance of the contract, Contractor shall follow notification requirements addressed in Paragraph H.4 of this annex, and shall preserve such VA information, records, logs and other evidence which are reasonably necessary to conduct a thorough investigation of the security incident.
4. *Prompt reporting:* In the event of any security incident as described in Paragraph 3.H.3, Contractor shall promptly, within 1 hour of the suspected or confirmed incident by the Contractor, notify the OIG COR and the OIG ISD (53I), about the incident. This notification requirement is in addition to any other notification requirements which may be required by law or by this contract. Established Federal agency timeframes for reporting security incidents to the United States Computer Emergency Readiness Team (US-CERT), although not exhaustive, serve as a useful guideline for determining whether reports under this paragraph are made promptly. (See NIST Special Publication 800-61, Appendix J). Contractor acknowledges that VA has special reporting requirements for security violations under the "Department of Veterans Affairs Information Security Enhancement Act of 2006," Pub. L. No. 109-461 and, if necessary, is required to provide credit protection services if sensitive personal information has been compromised. OMB Memorandum 17-12, "Preparing for and Responding to a Breach of Personally Identifiable Information" also establishes reporting requirements for such security incidents.
5. *Timely production of VA information:* Contractor shall timely produce to the requestor (with the requestor being the OIG COR, a representative of the OIG COR, or OIG) VA information or records under the control of or in the possession of Contractor pursuant to the contract, which OIG, may request in furtherance of other audits, inspections, investigations, reviews, or litigation in which OIG is involved. Requests for production under this paragraph shall specify a deadline not less than seven calendar days for compliance which will determine whether response to the request has been made in a timely manner.
6. *Storage:* Contractor shall ensure that all storage of all VA information and records under the control of or in the possession of Contractor pursuant to the contract are performed within the United States of America.
7. *Content capturing:* In support of the investigation of security incidents as described in Paragraph 3.H.3, as well as other investigations under the purview of OIG, Contractor will maintain the capability to capture full-content network traffic between the Internet and any VA information systems operated by Contractor in the performance of the contract. When permissible under applicable law, Contractor shall initiate the capture of network traffic, if not already occurring, at the request of the OIG COR, a representative of the OIG COR, or OIG.

8. *No expectation of privacy:* Contractor understands that users accessing OIG-provided information systems operated by Contractor or the VA in the performance of this contract have no reasonable expectation of privacy regarding any communications or information transiting or stored on OIG provided information system. Contractor shall obtain consent from all users accessing OIG provided information and information systems maintained, operated, or used by Contractor under this contract, to monitoring and disclosure of any communications or information transiting or stored on these information systems for any purpose, by providing users with OIG-approved network banners at all logins and points of access, and by incorporating such notice in its user terms of service as appropriate.

I. Contractor-Provided Inventory Restrictions

1. *General Prohibitions:* Contractor is prohibited from proposing or using foreign-sourced hardware, firmware, or software that is prohibited or blocked by Federal Law, Federal regulation, or Federal sanction including but not limited to:
 - Pub. L. 115-232 Section 889(a)(1)(A) [implemented in Federal Acquisition Regulation 52.204-24 and 52.204-25].
 - <https://home.treasury.gov/policy-issues/financial-sanctions/sanctions-programs-and-country-information>
 - <https://www.cbp.gov/trade/programs-administration/forced-labor/withhold-release-orders-and-findings>
2. *Source Prohibitions:* Contractor shall only use inventory that are obtained from a bona fide company incorporated within the United States. Inventory that is manufactured in China may be acceptable if not prohibited by §3.1.1 of this Security Annex and if the US-based Company is responsible for all legal claims and obligations for the particular inventory. Companies that solely function as a reseller or rebRANDER but provides no further legal representation for manufacturers based in China do not meet this requirement. OIG currently prohibits any hardware, firmware, or software sourced from North Korea, Russia, Iran, Belarus, and Eritrea. OIG requires additional security and supply chain support for Ukraine-based hardware, firmware, or software.
3. *Gray Market:* Used, refurbished, or remanufactured parts may be provided. No gray market supplies or equipment shall be provided. Gray market items are original equipment manufacturers (OEM) goods intentionally or unintentionally sold outside an authorized sales territory or sold by non-authorized dealers in an authorized sales territory.
4. *Counterfeits:* No counterfeit supplies or equipment shall be provided. Counterfeit items include unlawful or unauthorized reproductions, substitutions, or alterations that have been mismarked, misidentified, or otherwise misrepresented to be an authentic, unmodified item from the original manufacturer, or a source with the express written authority of the original manufacturer or current design activity, including an authorized aftermarket manufacturer. Unlawful or unauthorized substitutions include used items represented as new, or the false identification of grade, serial number, lot number, date code, or performance characteristics.

5. *Vendor Requirements:* Vendor shall be an OEM, authorized dealer, authorized distributor or authorized reseller for the proposed equipment/system, verified by an authorization letter or other documents from the OEM. All software licensing, warranty and service associated with the equipment/system shall be in accordance with the OEM terms and conditions.
6. *Backdoor accounts and embedded credentials:* Contractor shall proactively take measures to ensure that the solution shall not have any accounts, passwords, or private/secret keys that cannot be changed, disabled, or removed by OIG. Contractor shall declare all such accounts to OIG ISD (53I) for authorization before such accounts can be considered for use.
7. *Software Bill of Materials and Supply Chain:* Within 10 business days of request by the OIG COR or OIG ISD (53I), Contractor shall submit a software bill of materials (SBOM), supply chain attestation, or software development attestation as specified by OIG. This may be requested on one or more occasions and shall be delivered at no increase in contract price.

J. Physical Controls

1. *General rule:* Contractor shall take reasonable and prudent measures to physically secure sensitive information along with devices and media storing sensitive information.
2. *Standards and criteria:* All sensitive information provided to or created by Contractor shall be secured as directed by this Security Annex and by other OIG policies, procedures, and instructions. OIG may modify or specify additional physical security controls.
3. *Public locations:* Contractor personnel shall not view/review sensitive data or otherwise put sensitive data at risk of unauthorized disclosure in any public location.
4. *Access Protection:* Contractor personnel shall log out of the OIG Kiteworks solution when not directly conducting work under the contract. Contractor personnel shall log out of the OIG Kiteworks solution when stepping away from their computer. Contractor personnel shall close the Kiteworks app on any mobile device when not directly conducting work under the contract.
5. *Laptop locking:* Contractor personnel shall lock the Windows session/screen when stepping away from the laptop, shall ensure the Windows session/screen lockout engages after 15 minutes of user inactivity, and shall shut down the laptop to engage the whole disk encryption if they step away for longer than 15 minutes when no Contractor or OIG staff is available to watch the laptop. Contractor shall never leave a laptop unattended in a public area.
6. *Non-laptop protection:* Other authorized devices storing or transmitting sensitive data shall engage password or encryption protection within 15 minutes of user inactivity. Contractor personnel shall completely power off these devices (a) when

they are placed in safes, vehicle trunks, or other secured storage or (b) when not able to implement password/encryption protection.

7. *Location security:* Devices and media shall be secured at VA and OIG sites as directed by OIG. OIG will determine whether storage at the VA, VA Contractor, or OIG site is sufficiently secure. Contractor shall follow OIG's instructions on securing data by other means or in other locations. Sensitive media and devices will be secured after working hours at VA, OIG, or Contractor sites instead of hotels or residences. Contractor must track and account for each instance when sensitive data, media, or devices have been authorized by Contractor or OIG to be taken to hotels, residences, and similar non-controlled locations.
8. *Securing laptops:* Laptops shall be secured using physical cable locks and securing the laptop to a solid object that is not moveable or easily disassembled. This physical cable lock requirement applies except when the laptop is within secured Contractor or OIG space, is secured at a VA site as agreed to by the OIG site representative, is secured in a (hotel) safe, or is being transported (including on aircraft). Laptops must be secured using a cable lock attached to the car frame when locked in a rental vehicle trunk.
9. *Transport or shipment:* Contractor shall obtain instructions from the OIG COR or OIG ISD (53I) regarding whether laptops, other devices, or media should be hand-carried to and from OIG or VA locations or securely shipped.

K. Returning the OIG Laptop and Other Authorized Devices or Media

OIG shall provide Contractor with instructions on how to securely return the laptop and any other devices or media to OIG once the work described in the contract is complete. Contractor must follow OIG instructions on returning the laptop, other devices, and media including but not limited to due dates.

L. Large Data Sets

If Contractor needs to create or retain a large data set (more than 999 records that include PII) – regardless of how accessed – Contractor shall obtain permission from the OIG COR and maintain a listing of these data sets for inspection by OIG. As part of the permission request, Contractor shall prepare a "Privacy Information Risk Management Plan" annually that describes:

1. Type of data Contractor will need to access,
2. How Contractor will access the data, including the type and location of equipment to be used and the department point of contact,
3. How the equipment will be used and associated controls (i.e., laptop is controlled by the department, thumb drive and internet access has been disabled),
4. How Contractor will obtain for its own records any analysis of the data performed, any data subsets, or any other needed data sets, and

5. Procedures to keep a record of large data sets removed from VA, including name, date, how the data was transferred to Contractor, and location of the data in OIG's systems or in the OIG-provided laptops or media.

M. Access Controls, Passwords, and Security Tokens

1. *Criteria:* OIG generally requires compliance with VA's password policies and controls. However, OIG's password requirements differ as follows, which Contractor shall abide by:
 - a. Microsoft Windows and other user logon accounts shall be at least 15 characters when a password and shall be at least 6 or more characters for the VA PIV PIN.
 - b. Administrator and server/service accounts on any system used directly for this contract shall be 20 characters or longer. 2-factor token passwords for administrator/elevated accounts shall be 8 characters or longer.
 - c. Whole disk encryption passphrases shall be 15 characters or longer.
 - d. Public Key Infrastructure (PKI) and other encryption passphrases shall be 15 characters or longer (authorized mobile devices may use 8 characters per VA's password policy).
 - e. If 20 characters or longer, passphrases may contain dictionary words, but still shall not violate the other requirements of VA's password policies and controls.
 - f. If authorized for WiFi and passwords are used instead of certificates, passwords shall be 20 characters or longer and shall completely comply with VA's password policies including the restrictions on words.
2. *Character defined:* For the purpose of these password requirements, the term "characters" includes alphanumeric characters, non-alphanumeric characters, and spaces that are acceptable to the system or device as a password.
3. *Escrow and on-demand:* All passwords and passphrases for equipment approved for use under this contract shall be provided to the OIG ISD (53I) upon demand. Passwords, passphrases, tokens, and certificates for system or shared accounts will be escrowed as specified by the OIG CIO or OIG ISD (53I).
4. *Tokens and certificates:* Security tokens and security certificates shall meet current NIST requirements, and Contractor shall obtain approval from the OIG ISD (53I) prior to their use. Access code requirements for tokens shall be determined by the OIG ISD (53I) based on the token specifications. Security certificates for systems within the VA network must be obtained from VA through OIG IT staff. Contractor personnel will comply with two-factor authentication requirements as specified by the OIG ISD (53I) or OIG COR.

N. Encryption

Contractor shall meet all of the following requirements prior to using or

implementing any encryption to protect sensitive data:

1. Use encryption that is NIST Federal Information Processing Standard (FIPS) 140-2 or 140-3 certified.
2. Provide the NIST validation certificate number for each instance where Contractor uses encryption.
3. Provide information on the system, software, and program used for encryption, as requested by OIG.
4. Ensure recovery of all encrypted information to the OIG ISD's satisfaction.
5. Obtain the OIG ISD's approval of all encryption prior to Contractor using it to protect data either in storage or in transit.

<https://csrc.nist.gov/projects/cryptographic-module-validation-program> provides information on FIPS 140-2 and 140-3 approved cryptographic modules and other information on encryption requirements.

Government Furnished Equipment (GFE) / Government Furnished Information (GFI) / Government Furnished Software (GFS)

The VA OIG will provide Government Furnished Equipment (GFE), Government Furnished Information (GFI) and Government Furnished Software (GFS) for existing systems as required, to provide the services and support outlined in the SOW.

Packaging, Packing, and Shipping Instructions

The Contractor shall ensure that all items are preserved, packaged, packed, and marked in accordance with best commercial practices to meet the packing requirements of the carrier and to ensure safe and timely delivery at the intended destination. All data and correspondence submitted shall reference:

1. The Agency Delivery Order Number
2. The CIO-CS Delivery Order Tracking Number
3. The government end user agency
4. The name of the COR

Containers shall be clearly marked as follows:

1. Name of Contractor
2. The name of the COR
3. The Agency Delivery Order Number
4. The CIO-CS Delivery Order Tracking Number
5. Description of items contained therein
6. Consignee(s) name and address